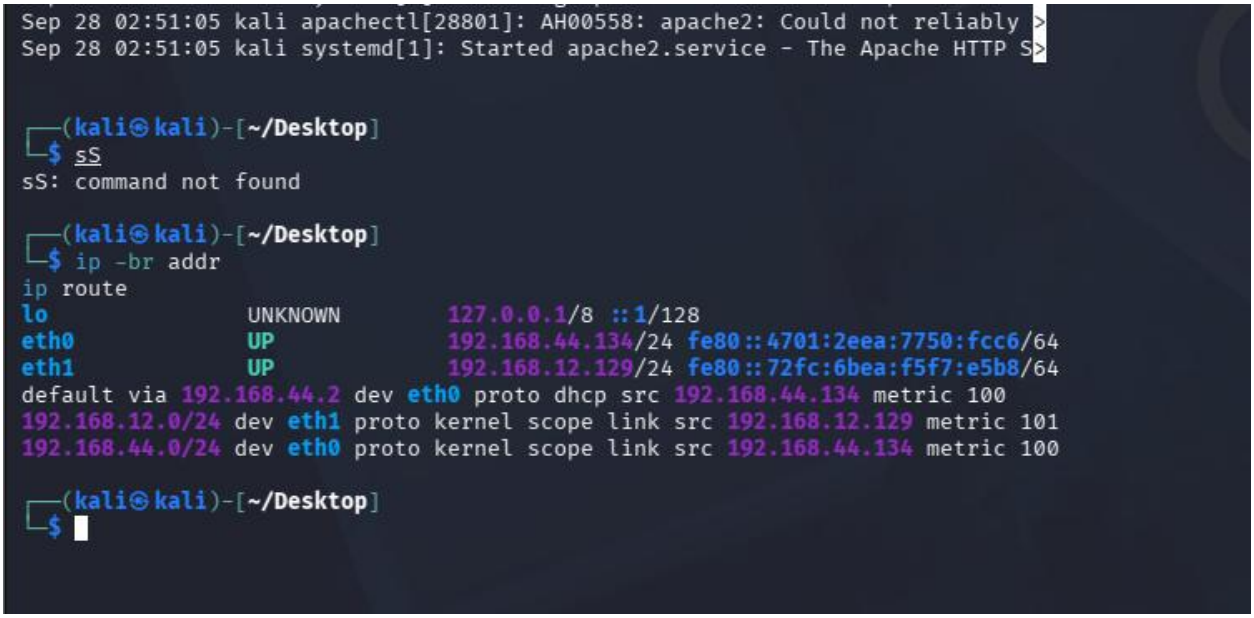
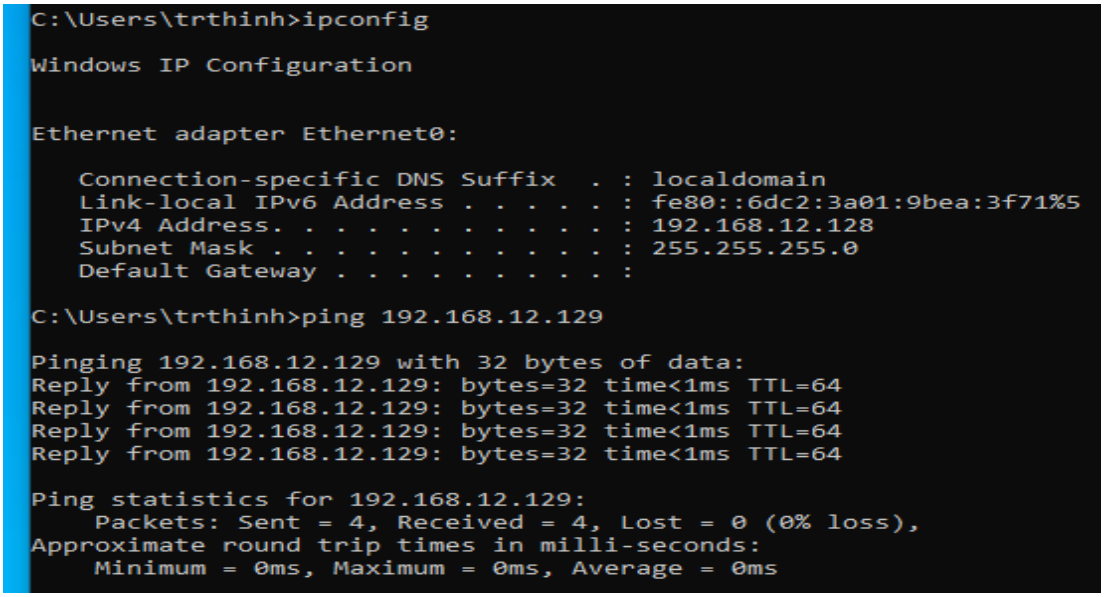
BÀI 2: SESSIONS, HTTPS VÀ RECAPTCHA

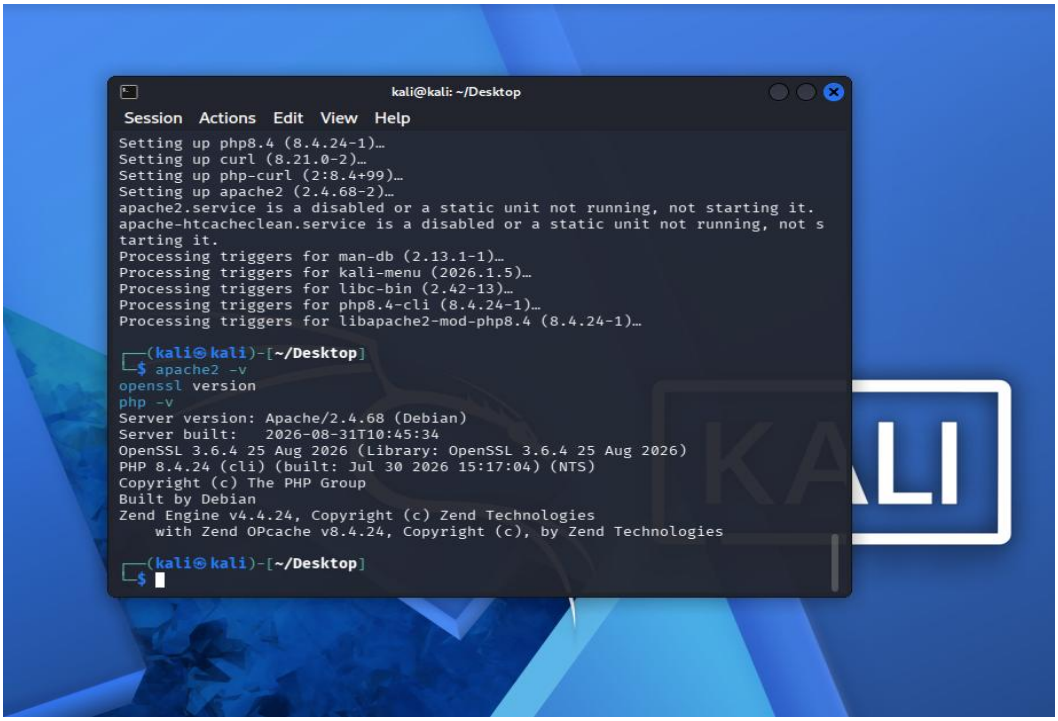
Trần Tăng Trường Thịnh 2387710939



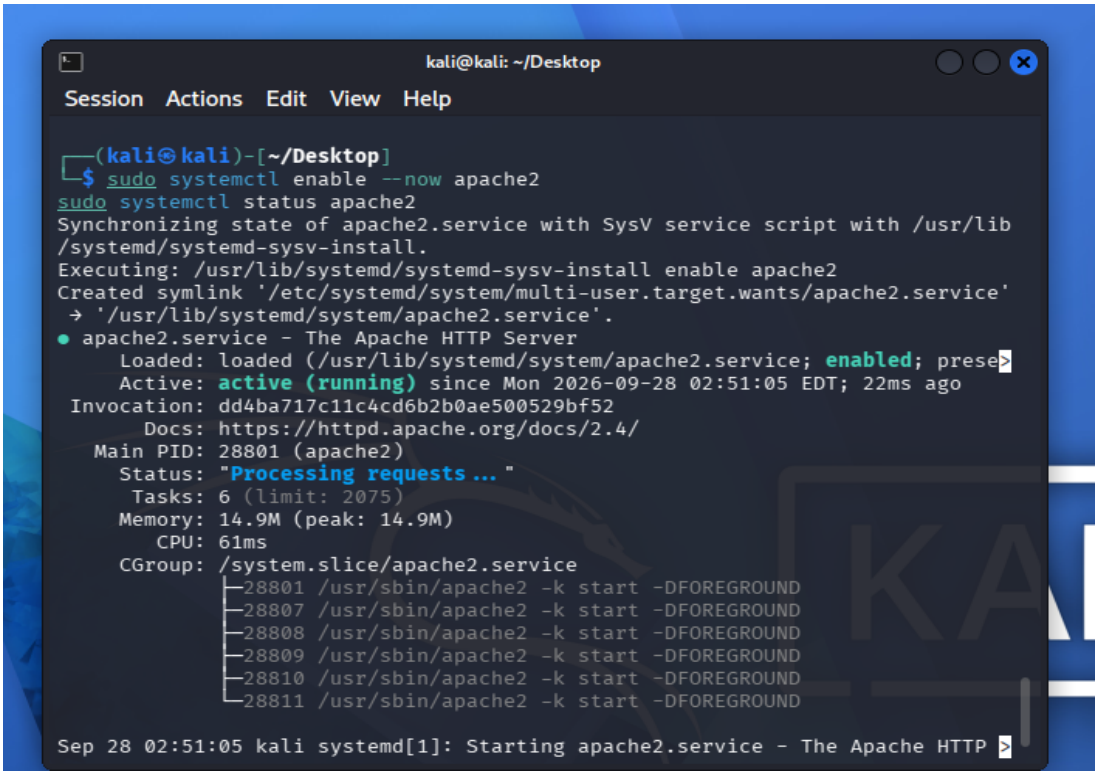
Hình 1: Địa chỉ IP máy Kali (192.168.12.129)



Hình 2: Kiểm tra kết nối từ máy mục tiêu



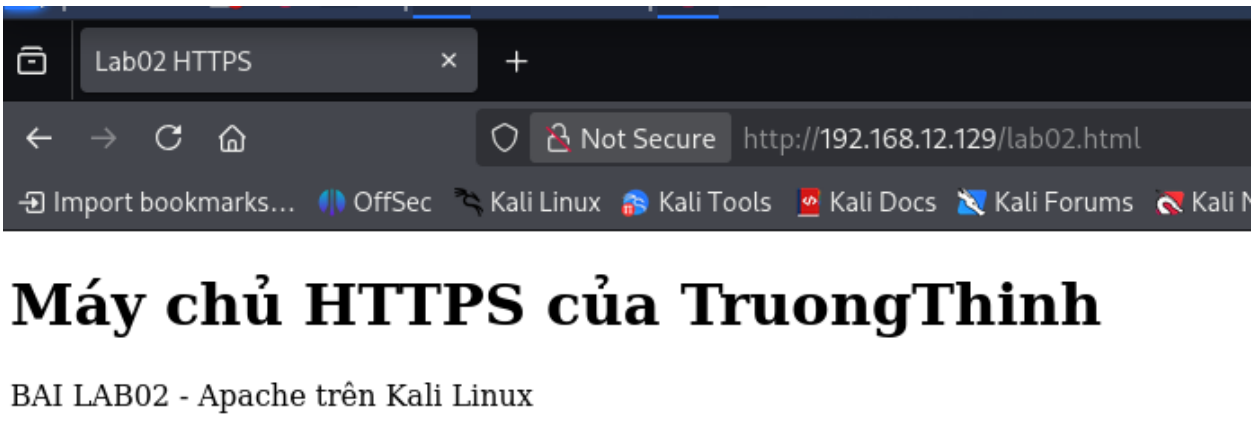
Hình 3: Kiểm tra cài dặt các dịch vụ trên Kali



Hình 4: Khởi động Apache



Hình 5: Kiểm tra hoạt động của trang web



Hình 6: Truy cập trang web bằng Firefox trên Kali



Hình 7: Truy cập trang web trên máy mục tiêu

2.3 KIỂM TRA HEARTBLEED VÀ CẬP NHẬT OPENSSL

```
┌──(kali㉿kali)-[~/Desktop]
└─$ sudo apt update
apt policy openssl libssl3
Get:1 https://kalimirror.velden.media/kali kali-rolling InRelease [34.0 kB]
Get:2 https://kalimirror.velden.media/kali kali-rolling/main amd64 Packages [21.6 MB]
Get:3 https://kalimirror.velden.media/kali kali-rolling/main amd64 Contents (deb) [54.1 MB]
Fetched 75.7 MB in 1min 45s (724 kB/s)
1979 packages can be upgraded. Run 'apt list --upgradable' to see them.
openssl:
  Installed: 3.6.4-1
  Candidate: 3.6.4-1
  Version table:
 *** 3.6.4-1 500
        500 http://http.kali.org/kali kali-rolling/main amd64 Packages
        100 /var/lib/dpkg/status
libssl3:
  Installed: (none)
  Candidate: (none)
  Version table:
```

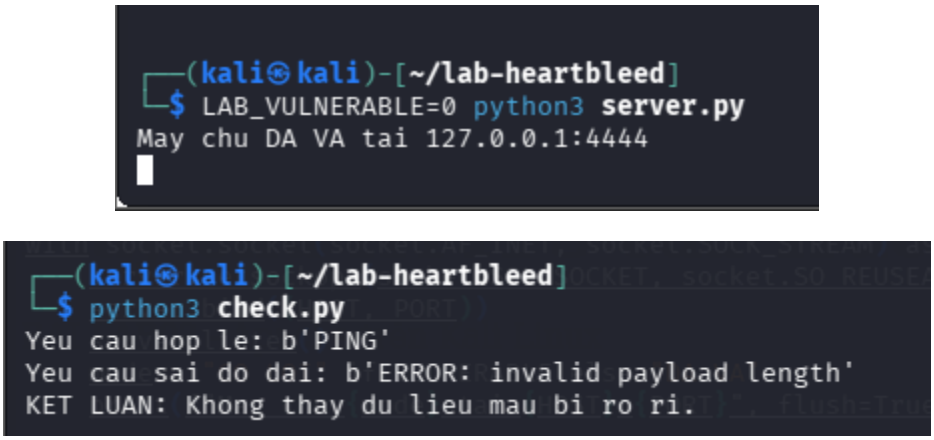
```
┌──(kali㉿kali)-[~/Desktop]
└─$ dpkg -l | grep -E '^(ii) +openssl|^(ii) +libssl'
ii  libssl3t64:amd64                    3.6.4-1                  amd64        Secure Sockets Layer toolkit - shared libraries
ii  openssl                             3.6.4-1                  amd64        Secure Sockets Layer toolkit - cryptographic utility
ii  openssl-provider-legacy             3.6.4-1                  amd64        Secure Sockets Layer toolkit - cryptographic utility
```

Hình 8: Kiểm tra môi trường và phiên bản công cụ OpenSSL

```
┌──(kali㉿kali)-[~]
└─$ cd ~/lab-heartbleed
LAB_VULNERABLE=1 python3 server.py
May chu CO LOI tai 127.0.0.1:4444
```

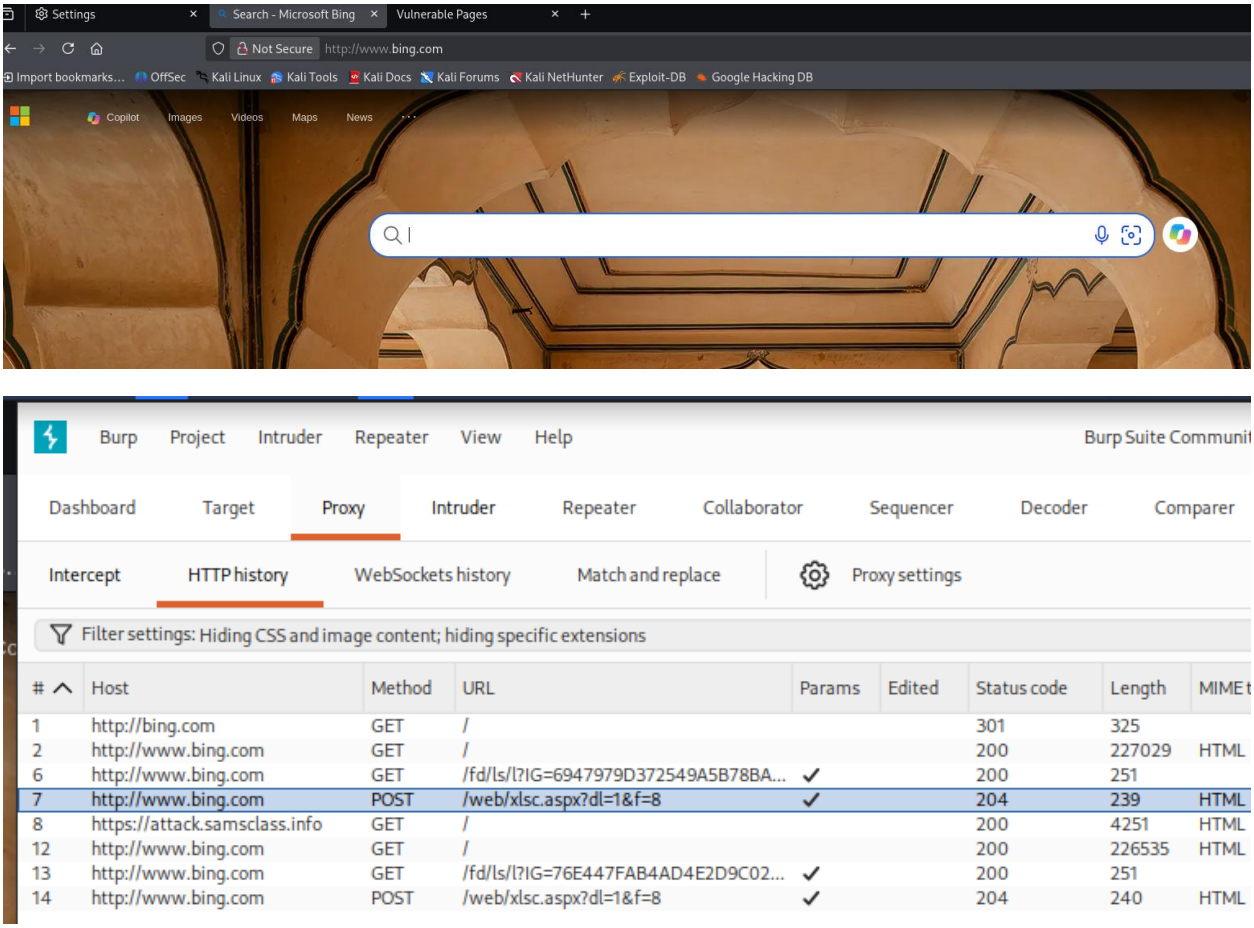
```
kali-linux-2026.1-vmware... ✕  Windows 10 x64 ✕
1  2  3  4
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ cd ~/lab-heartbleed
python3 check.py
Yeu cau hop le: b'PING'
Yeu cau sai do dai: b'PINGLAB_SECRET demo-hotenSV-MSSV'
KET LUAN: Phat hien ro ri du lieu - may chu co loi.
```

Hình 9: Chạy máy chủ có lỗi và phát hiện

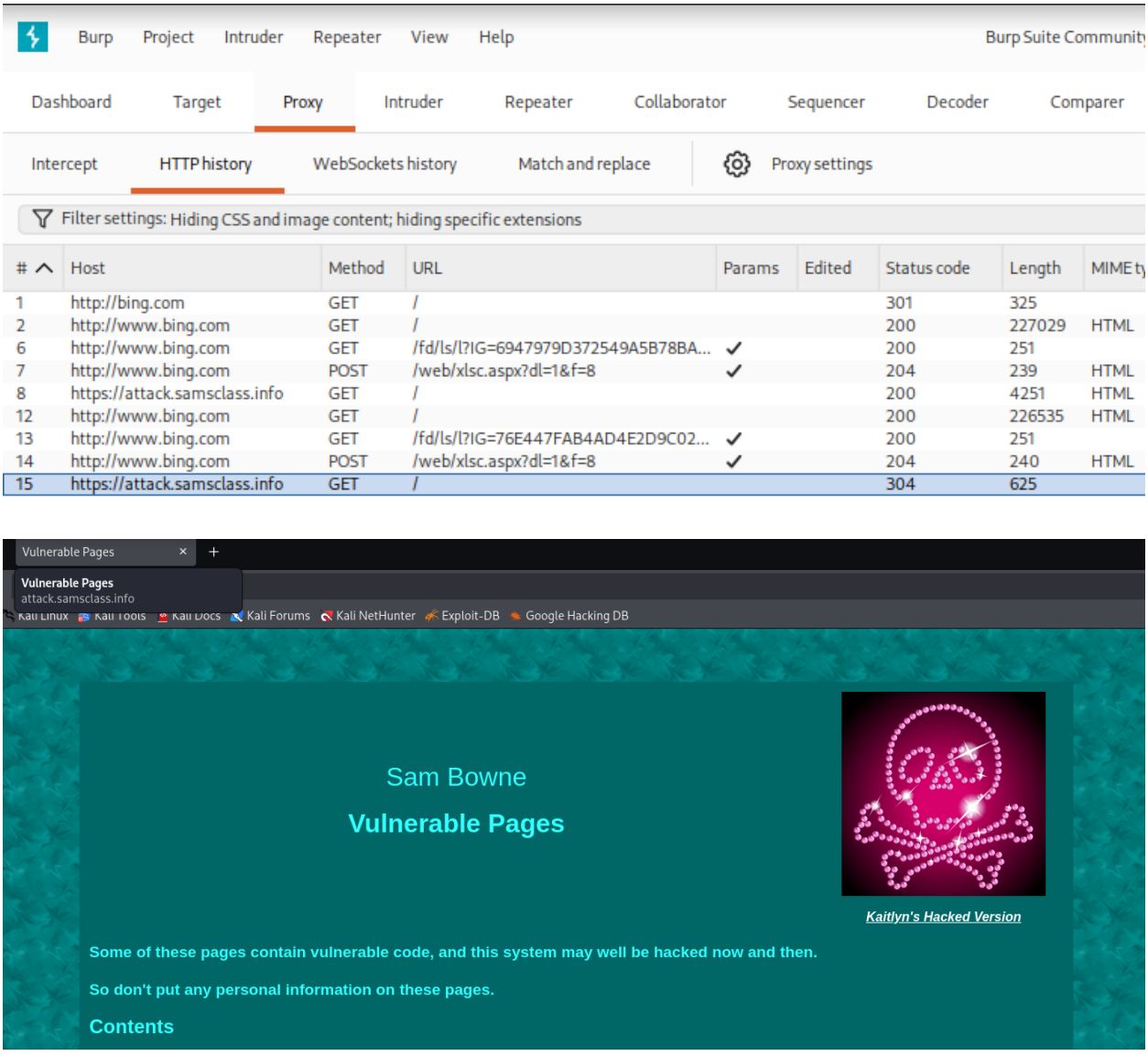


Hình 10: Chu trình phát hiện → vá →kiểm tra lại.

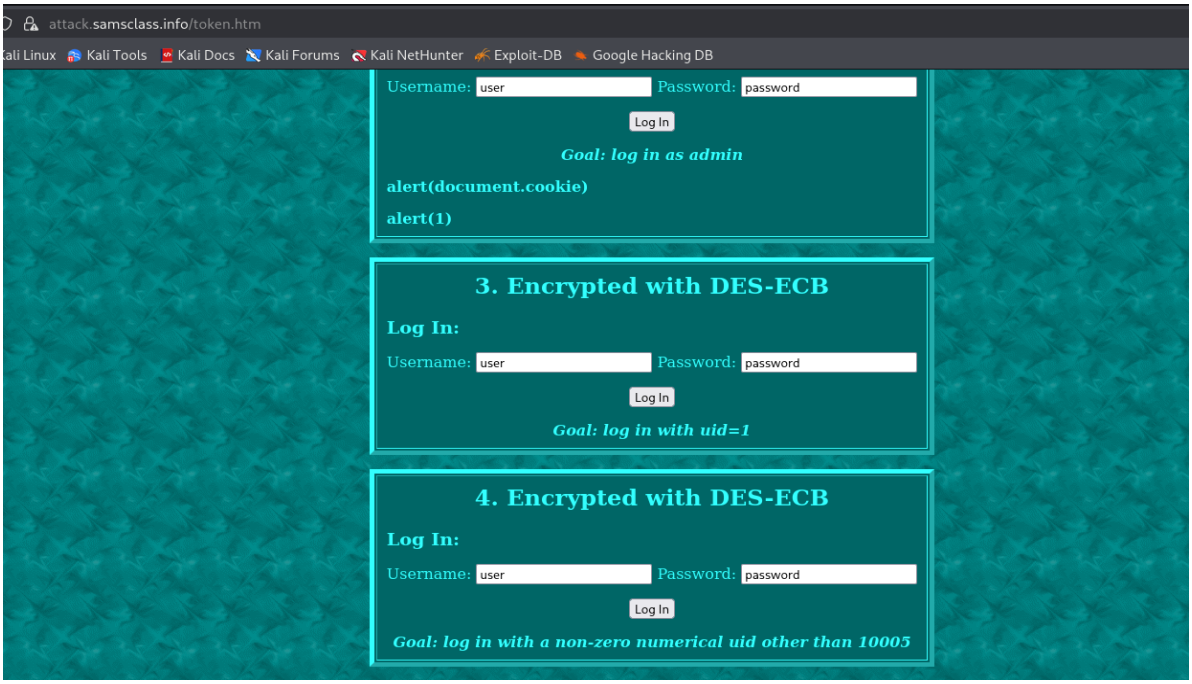
2.4 KHAI THÁC THẺ MÃ HÓA ECB VỚI CÔNG CỤ BURP SUITE



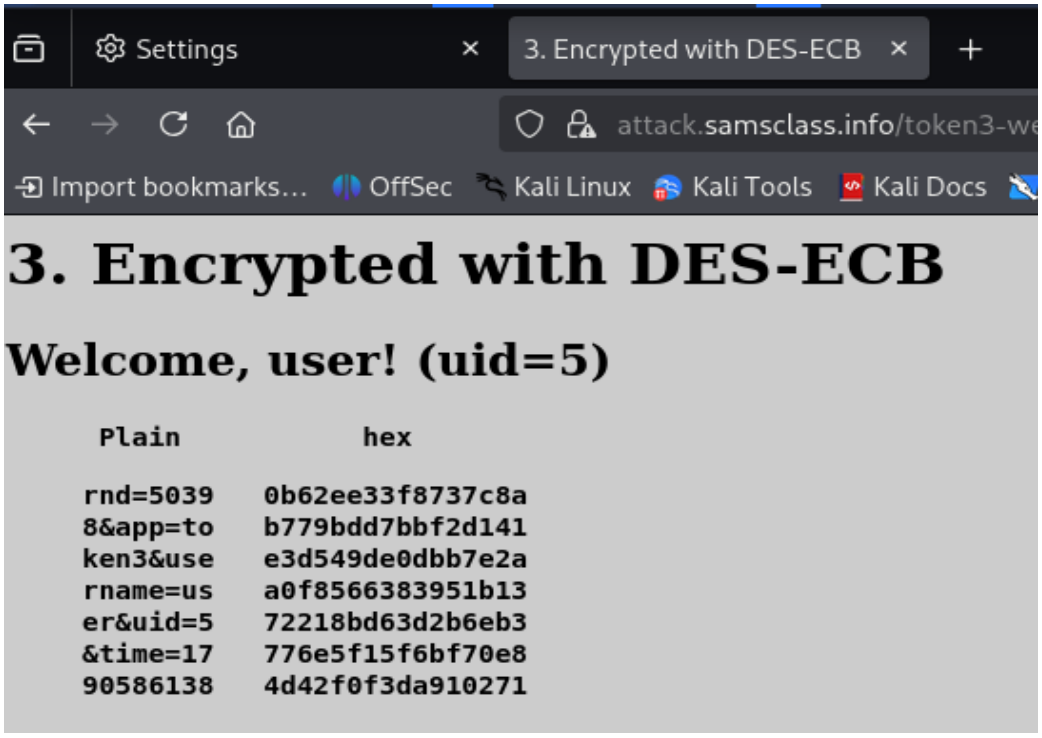
Hình 11: Burp suite hiển thị các yêu cầu trên tab Proxy khi truy cập http://bing.com trên Firefox



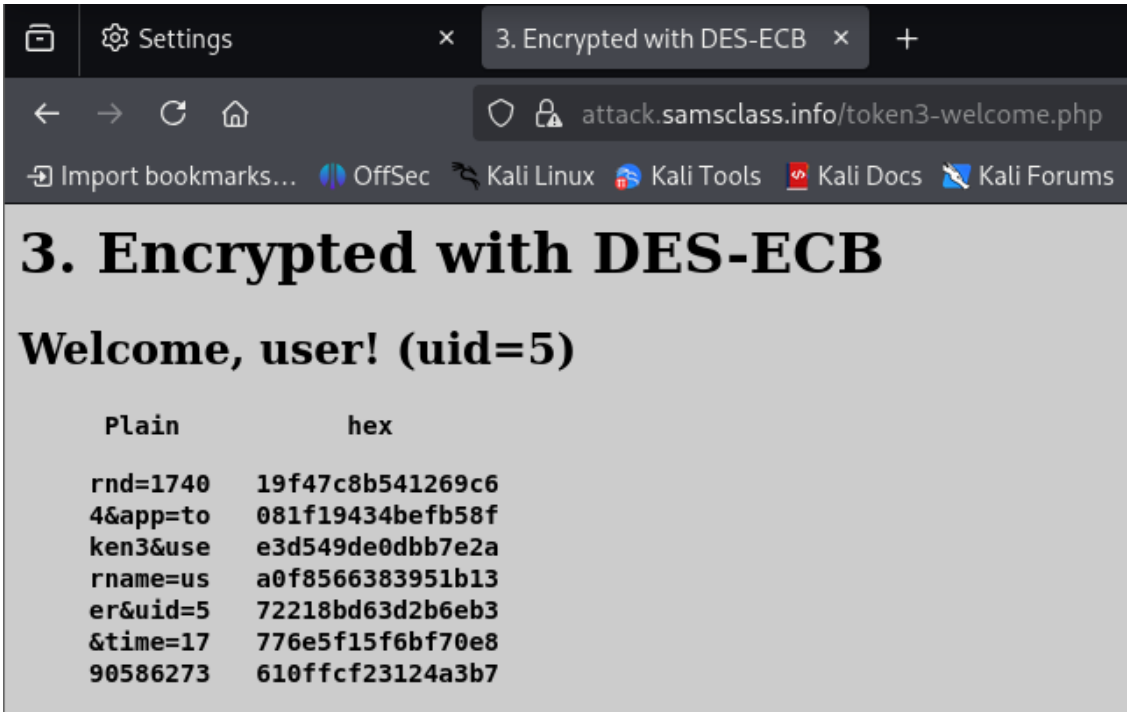
Hình 12: Trang web được hiển thị và công cụ Burp suite hiển thị các yêu cầu



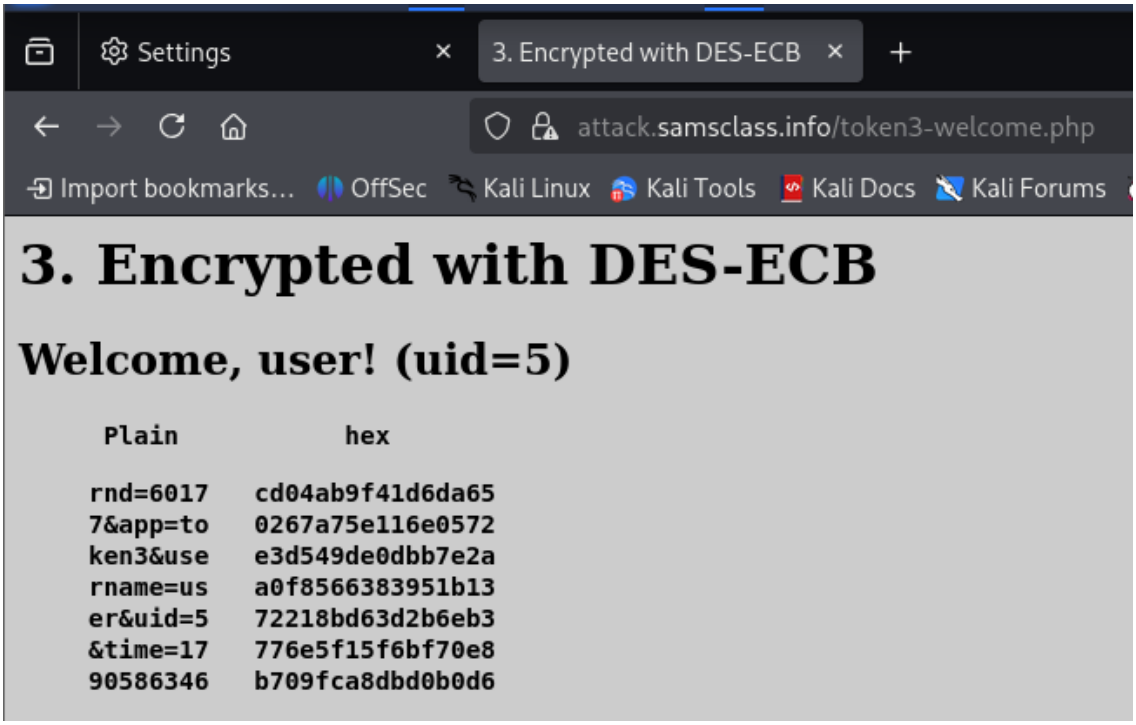
Hình 13: Thử thách thứ 3



Hình 14: Trang “Welcome” xuất hiện



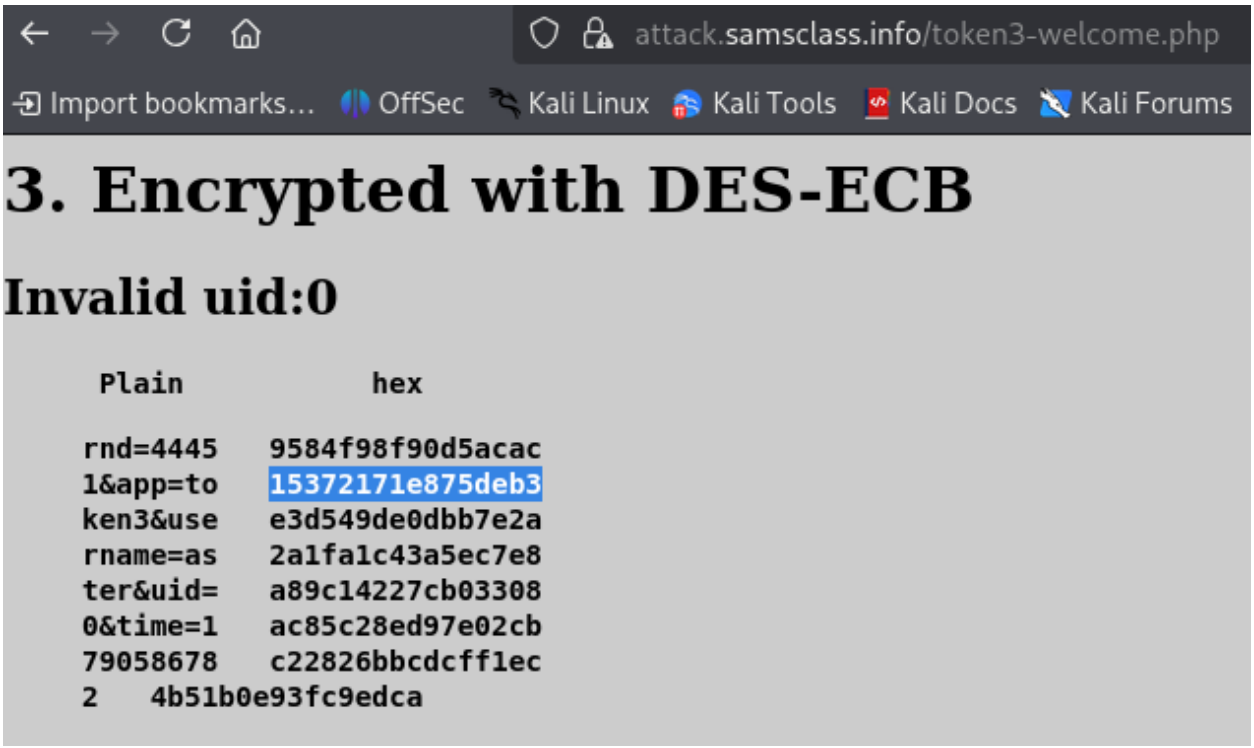
Hình 15: Đăng nhập lần 2



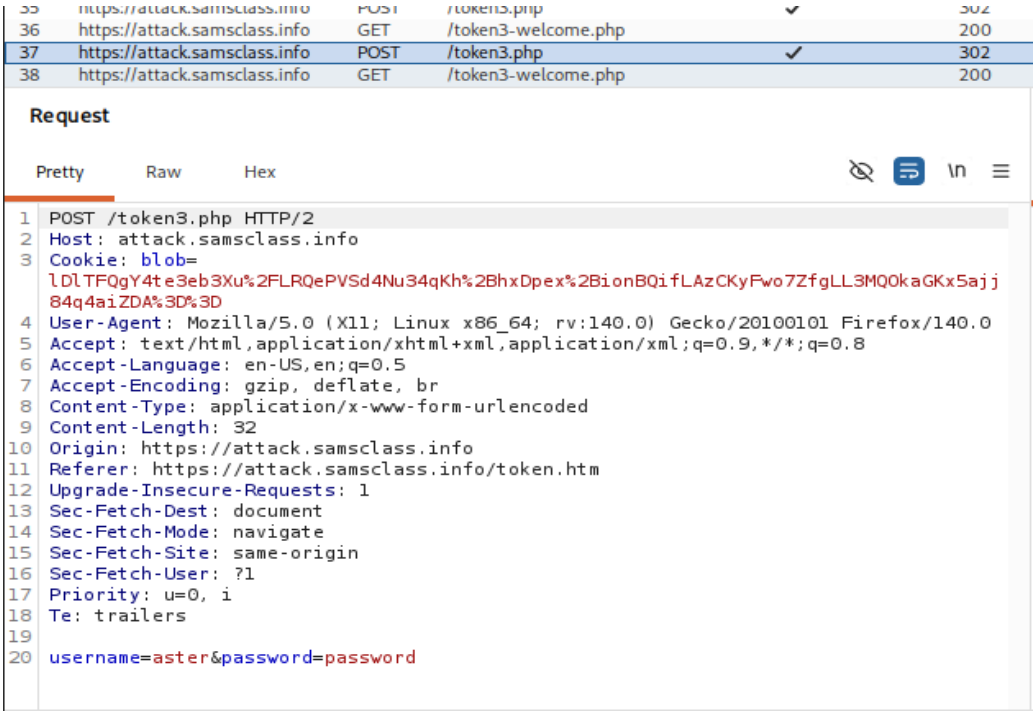
Hình 16: Đăng nhập lần 3

⇒ Các tham số "*rnd*" và "*time*" thay đổi theo từng yêu cầu, nhưng chiều dài không bao giờ thay đổi và các dòng văn bản thuần túy *plaintext* không bao giờ thay đổi, bao gồm các dòng **thứ 3, thứ 4, và thứ 5**. Các giá trị "*hex*" trong những dòng này không bao giờ thay đổi, cho thấy không có *nonce* ngẫu nhiên bao gồm mã hóa.

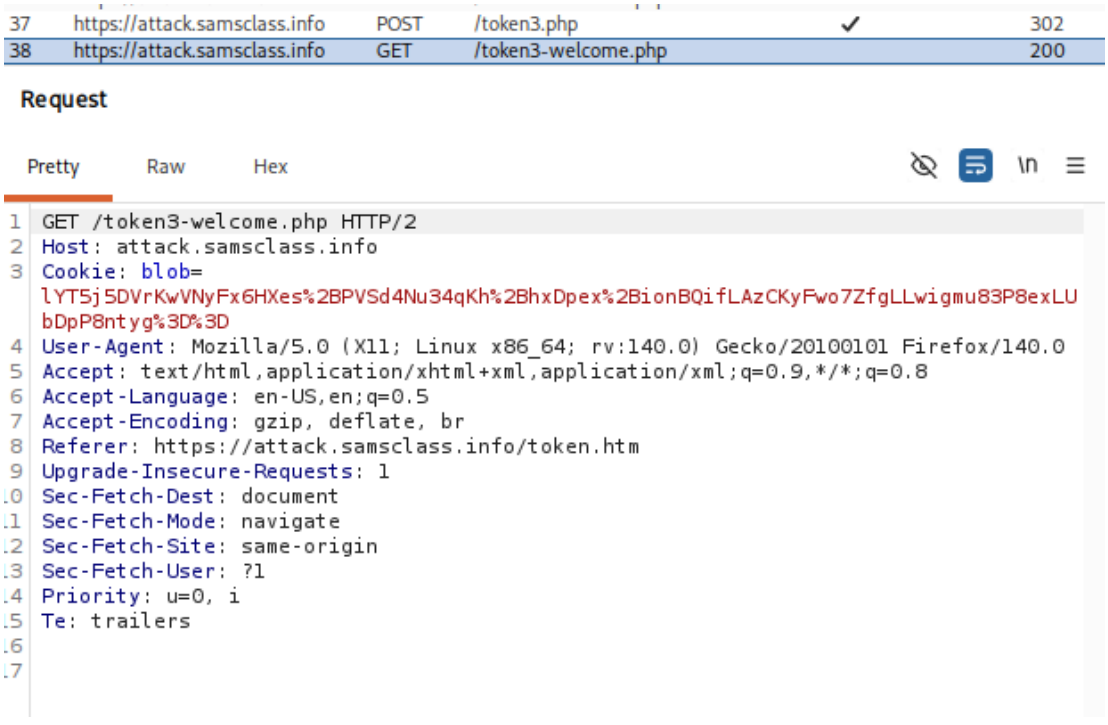
⇒ Đây là điểm yếu cơ bản của ECB.



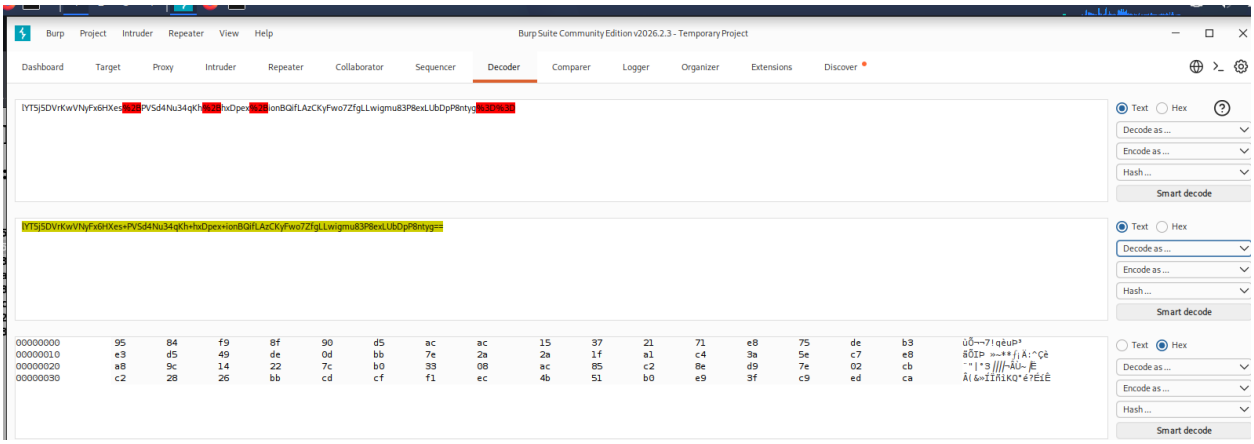
Hình 17: Đăng nhập với username aster và Nhận một dòng với "1&"



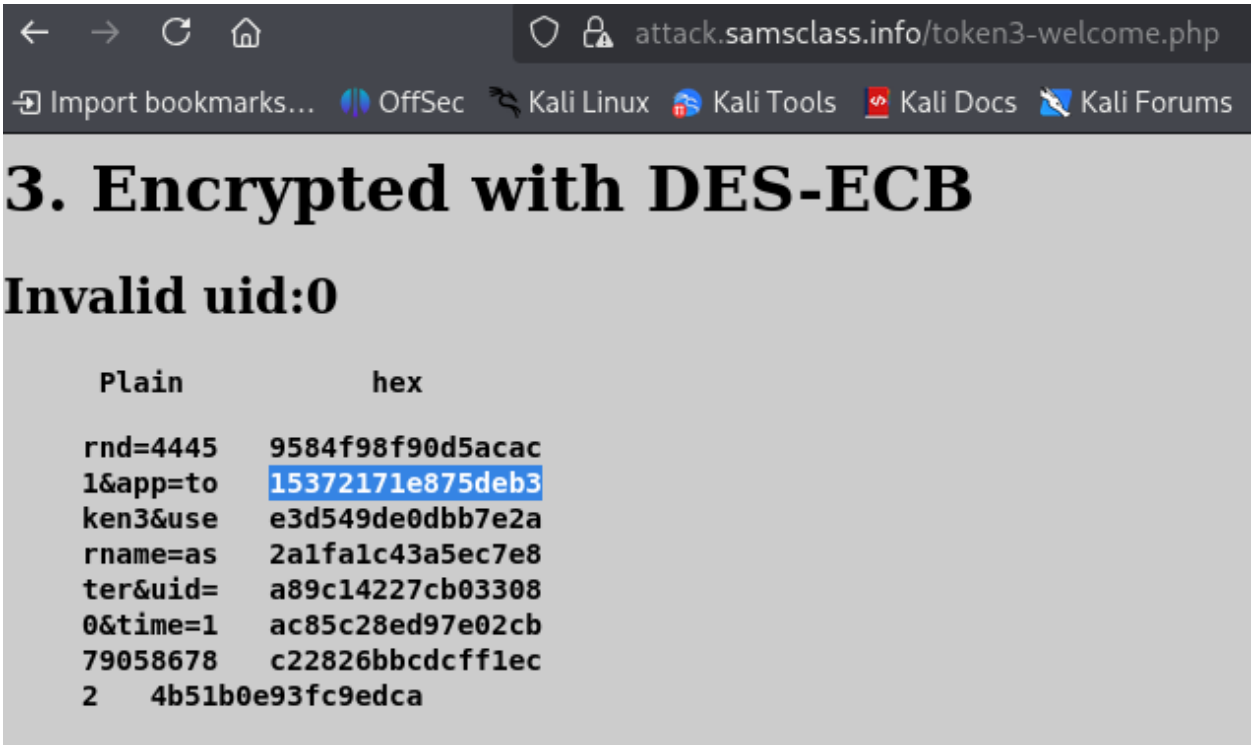
Hình 18: Yêu cầu POST gửi username và password đến máy chủ server



Hình 19: Yêu cầu GET gửi một *blob* dài các dữ liệu được mã hóa tới máy chủ

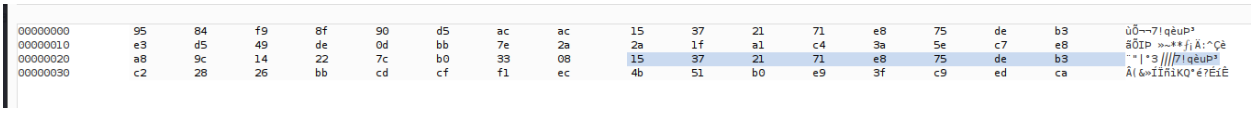


Hình 20: Giải mã tham số cookie blob bằng công cụ Decoder trong Burp Suite.

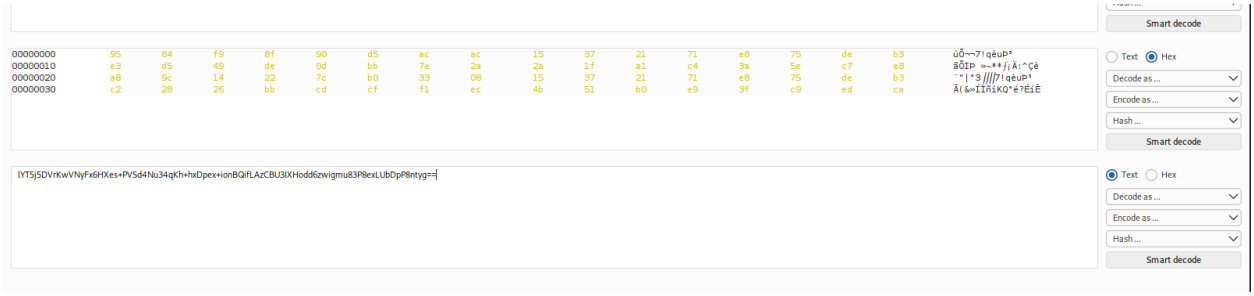


15	37	21	71	e8	75	de	b3
2a	1f	a1	c4	3a	5e	c7	e8
ac	85	c2	8e	d9	7e	02	cb
4b	51	b0	e9	3f	c9	ed	ca

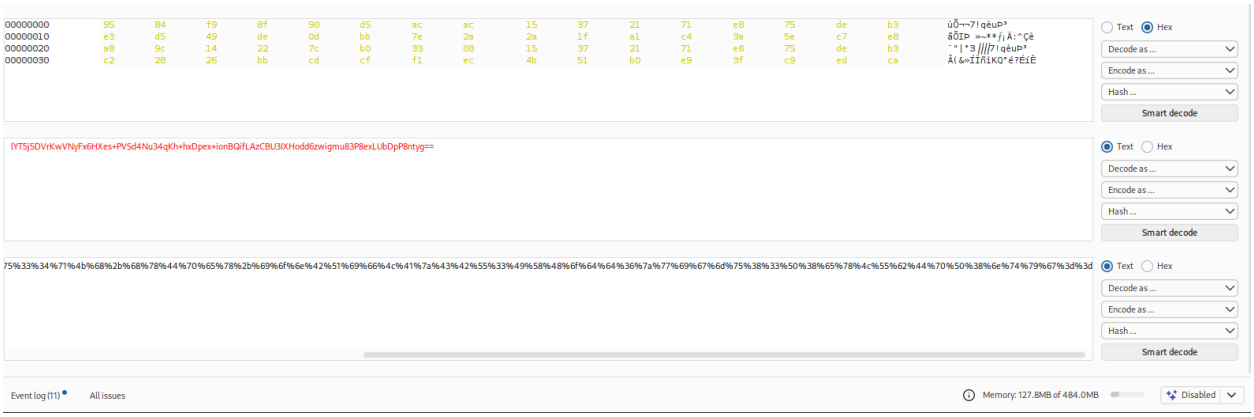
Hình 21: So sánh các giá trị hex, với “hex” được hiển thị trên trang “Welcome”.



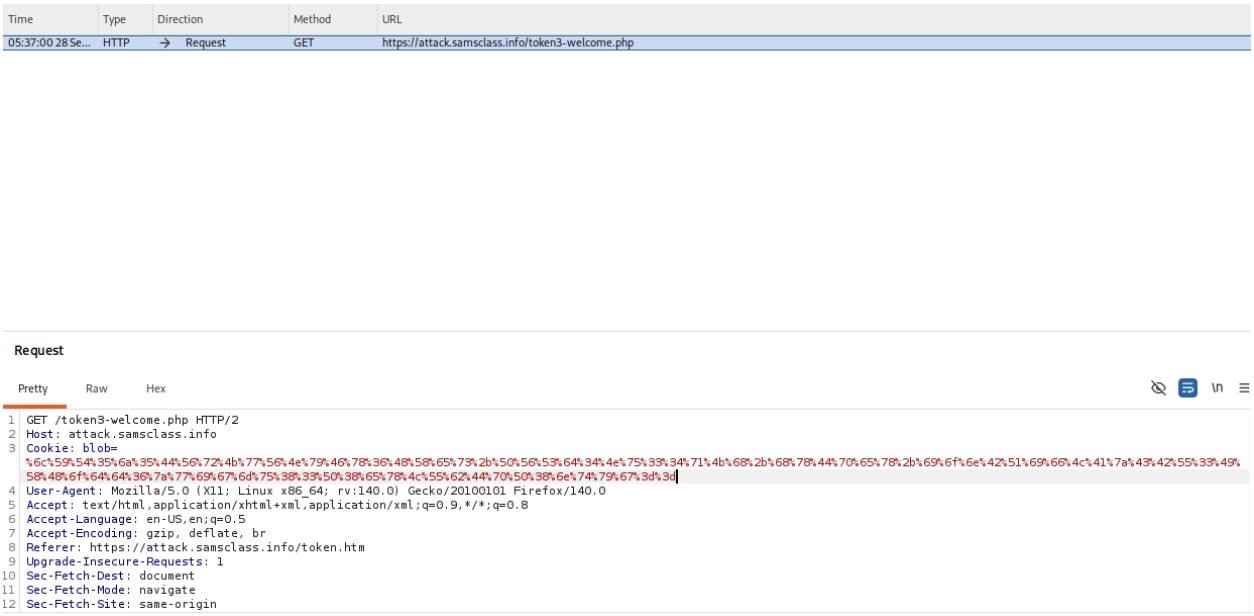
Hình 22: Đổi 8 byte trong hàng đầu tiên vào hàng thứ 3



Hình 23: Dòng văn bản Base64 xuất hiện trong một hàng mới



Hình 24: Hàng mới xuất hiện, chứa một blob dài của văn bản được mã hóa *URL encoded*



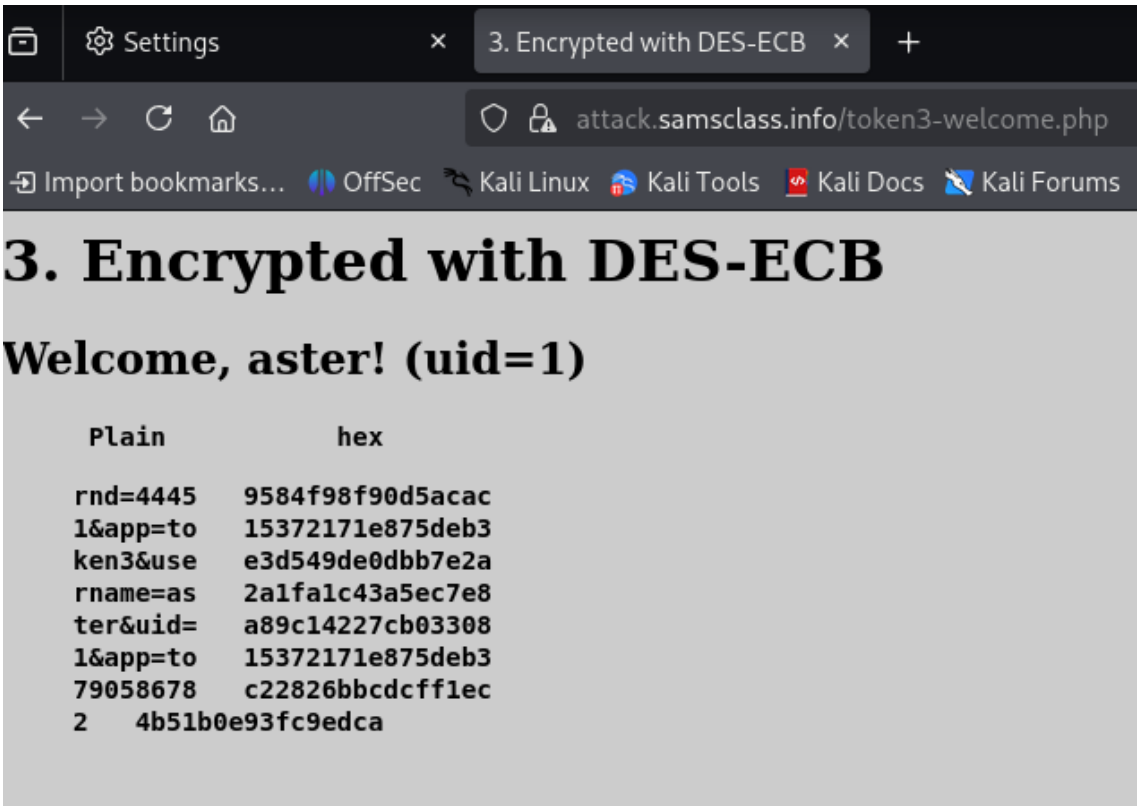
Time	Type	Direction	Method	URL
05:37:00 28 Se...	HTTP	→ Request	GET	https://attack.samsclass.info/token3-welcome.php

Request

Pretty Raw Hex

```
1 GET /token3-welcome.php HTTP/2
2 Host: attack.samsclass.info
3 Cookie: blob=
  %6c%59%54%35%6a%35%44%56%72%4b%77%56%4e%79%46%78%36%48%58%65%73%2b%50%56%53%64%34%4e%75%33%34%71%4b%68%2b%68%78%44%70%65%78%2b%69%6f%6e%42%51%69%66%4c%41%7a%43%42%55%33%49%
  58%48%6f%64%64%36%7a%77%69%67%6d%75%38%33%50%38%65%78%4c%55%62%44%70%50%38%6e%74%79%67%3d%3d
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Referer: https://attack.samsclass.info/token.htm
9 Upgrade-Insecure-Requests: 1
10 Sec-Fetch-Dest: document
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-Site: same-origin
```

Hình 25: Dán vào dữ liệu đã sao chép trước đó,



Hình 26: Trình duyệt web hiện thị với tên “aster”